Seen: OWASP Top 10 review

Repository github.com/surenganne/seen · branch build/seen-v1 · 19 Oct 2026 (IST) · gstack /cso --owasp, daily mode (8/10 gate)

0	3	2	0
confirmed findings at the 8/10 gate	below-gate defects fixed, test first	decision items for the owner	known CVEs (npm, pip-audit)

Scope and method

Local dashboard API (FastAPI on 127.0.0.1), team server skeleton (FastAPI + Postgres), Claude Code hooks and CLI (stdlib Python), React dashboard, Dockerfiles and Compose, GitHub Actions. Phases: architecture model, dependency supply chain, CI/CD, OWASP A01–A10, false-positive filtering. Every candidate was scored by an independent verifier that saw only the file and line. Fixes were reproduced on the live Docker stack.

Baseline checks (Minfy §5.1)

Check	Result	Evidence
Secrets (A02/A07)	pass	Team server refuses to start in production with a bootstrap key under 32 characters (test). `deploy/.env` is generated at 0600 and gitignored. Token-shaped strings in history are seeded synthetic benchmark data; `.gitleaks.toml` added with that allowlist.
Auth throttling (A07/A04)	pass	Per-client-IP limit (8 failures / 60 s); once locked, even a correct key waits, so the lockout is not an oracle. No per-account lockout. Keys are 256-bit random.
Security headers (A05)	pass	Live `curl`: `X-Frame-Options: DENY`, CSP with `script-src 'self'`, `frame-ancestors 'none'`, `object-src 'none'`, `nosniff`, `Referrer-Policy`, `Permissions-Policy`, no server banner. Playwright fails on any CSP violation.
Containers (A05)	pass	Dashboard image runs as non-root (live `id -u` → 10001). The team image declares `USER seen` (not run live: it needs `deploy/.env`). Ports published on 127.0.0.1 only.
Supply chain (A06/A08)	pass	`npm audit` (prod and dev): 0. `pip-audit` on 84 locked runtime packages and dev group: 0. `uv.lock` and `package-lock.json` tracked; images use `uv sync --frozen` and `npm ci`.
Access control (A01/A07)	pass	Bootstrap key compared with `hmac.compare_digest` on bytes; API keys stored as SHA-256; project scoping and member-only detail on every team route. Local writes need `X-Seen-Request` (live: 403 without it); DNS rebinding blocked (live: 400 for a foreign Host).
Injection (A03)	pass	All SQL parameterised (the only f-strings interpolate a constant column list). No `eval`/`exec`/`pickle`/`shell=True`/unsafe YAML. Git runs through a wrapper that disables fsmonitor, hooks, external diff, pager, protocols and ssh. Config-supplied regexes go through a deny-by-default ReDoS check. CSV export neutralises formula cells. No HTML escape hatches in the UI.
SSRF (A10)	pass	The only outbound call is `seen sync` to a server URL from local config; plain http is refused except for localhost.
Logging (A09)	pass	Append-only, hash-chained audit trail (UPDATE/DELETE rejected by triggers); every state-changing route writes an event (route-walk test); no PII values, prompts or secrets in events (verified on the real ledger).

PII at rest (DPDP)	decision	See decision item 2.

Fixed in this review (below the gate, real defects)

#	OWASP	Defect	Fix and proof
1	A01	`POST /api/audit/export` built the file name from an unvalidated `project` string, so `x/../../../escape` wrote outside `~/.seen/exports`. Reachable only by the same-origin page or a same-user process (verifier 3/10).	`ExportIn.project` now matches `^[A-Za-z0-9][A-Za-z0-9._-]{0,63}$`. Test `test_export_project_cannot_escape_exports_dir` RED → GREEN; live container returns 422.
2	A05	Team server served `/docs`, `/redoc` and `/openapi.json` without a key in production (verifier 3/10; every data route still required a key).	Disabled when `APP_ENV=production`. Test `test_production_hides_api_docs` RED → GREEN.
3	A08	CI used the third-party `astral-sh/setup-uv` on a mutable tag and had no `permissions:` block (verifier 5/10; no secrets in CI, no `pull_request_target`, no script injection).	All actions pinned to commit SHAs (tag kept as a comment); workflow token set to `contents: read`.

Also fixed: `test_dev_seed_refuses_real_home` assumed no real ledger existed; it now asserts the real ledger is unchanged. `.gstack/` (local audit reports) is now gitignored.

Decision items for the owner

#	Item	Risk	Options
1	Local dashboard read API has no login (`seen_local/app.py`).	On a shared multi-user host, another OS account can read change summaries, memory text, paths and stored prompt text over 127.0.0.1, bypassing the 0700 `~/.seen`. No web or remote path (verifier 5/10). Documented in the README.	A) per-launch token set by `seen serve --open` (cookie, constant-time check); B) Unix socket at 0600; C) accept for single-user laptops and keep documenting it.
2	Prompt text at rest (`changes.prompt_text`).	Default `redacted` stores structured identifiers as `[TYPE]`; names and free text are not detected. `full` mode stores raw prompts in plaintext SQLite (0600). No field-level or database encryption.	A) keep `redacted` default and require FileVault/BitLocker on dev machines; B) add SQLCipher or field-level encryption for `prompt_text`; C) default to `off`.

Gates after fixes

ruff clean · mypy clean · pytest 378 passed · PII benchmark ok · OpenAPI and web client regenerated and in sync · web lint, typecheck, Vitest 10 passed · Docker real-data dashboard healthy.

Disclaimer. This is an AI-assisted scan for common vulnerability patterns. It is not comprehensive and is not a substitute for a professional security audit or penetration test. For production systems handling personal data, engage a qualified security firm.